

Mini-projet d'audit SI – Partie Pratique

Un audit de sécurité consiste à évaluer le niveau de protection d'un système informatique (serveur, réseau, application) afin d'identifier les vulnérabilités et proposer des solutions pour les corriger.

Pour un professionnel en informatique, se familiariser avec cette démarche permet de comprendre les méthodologies, outils et bonnes pratiques utilisées dans le domaine.

Ce mini-projet propose un guide structuré pour réaliser un premier audit de sécurité, en passant par l'installation des outils, la détection des vulnérabilités et la mise en place des correctifs.

Structure du projet

Phase	Thème
1	Préparation de l'environnement et cartographie du système
2	Audit de sécurité et détection des menaces
3	Sécurisation et mise en conformité
4	Mise en place d'une surveillance continue
5	Rapport final
	Les attendus
	Exemple de plan de rapport

Contexte et Objectifs

Contexte

Cet audit permettra d'identifier, d'évaluer et de corriger les vulnérabilités d'un serveur linux utilisé pour héberger des services tels qu'un serveur web, une base de données, des applications internes.

Objectifs

- Détecter les vulnérabilités critiques et nouvelles menaces
- Mettre en place une surveillance avancée et une réponse aux incidents
- Tester la robustesse du système via des attaques simulées
- Assurer la conformité aux normes de cybersécurité actuelles
- Documenter les résultats et recommandations pour un suivi à long terme
- Se familiariser avec la démarche d'audit de sécurité

Phase 1 : Préparation de l'environnement et cartographie du système

Objectif

Mettre en place un environnement, installer les outils d'audit et effectuer une cartographie initiale du système avant l'analyse des vulnérabilités.

Installation et Configuration des Outils

Installation d'un serveur Linux

- Installer un logiciel de virtualisation (privilégier les solutions open-source, exemple VirtualBox)
- Déployer un serveur Linux (**Debian, Ubuntu, ...**) sur une machine virtuelle.
- Configurer le système avec un accès SSH sécurisé.

Mise à jour du système et vérification des configurations

Avant d'auditer la sécurité du serveur, il est essentiel de s'assurer que le système est à jour et que les outils de détection sont bien installés.

Etape 1 : Vérification des configurations

PARTIE A — Analyse approfondie du système et du noyau

Analyse avancée du noyau

Analyser :

```
uname -a  
uname -r  
uname -v  
cat /proc/version
```

Puis vérifier :

```
cat /boot/config-$(uname -r) | grep CONFIG_SECURITY
```

Et :

```
sysctl -a | grep kernel
```

Éléments à analyser :

- Version exacte du kernel
- Date de compilation
- Présence des mécanismes :

- ASLR
- Kernel Lockdown
- SELinux/AppArmor
- Protection mémoire
- Paramètres sysctl dangereux (exemple : ip_forward, randomize_va_space)

Vérification de la distribution et du cycle de support

```
lsb_release -a  
cat /etc/os-release  
apt policy
```

Éléments à regarder :

- Version LTS ?
- Encore supportée ?
- Dépôts activés ?
- Dépôts non officiels présents ?

PARTIE B — Analyse avancée des comptes utilisateurs

Analyse des comptes

```
awk -F: '{print $1, $3, $7}' /etc/passwd
```

Objectif :

- Identifier les UID 0
- Identifier comptes système vs comptes humains
- Détecter comptes avec shell interactif

Comptes privilégiés

```
getent group sudo  
cat /etc/sudoers  
sudo -l
```

À analyser :

- Combien d'utilisateurs ont des privilèges élevés ?
- Y a-t-il des règles NOPASSWD ?
- Wildcards dangereuses ?

Comptes verrouillés / dormants

```
passwd -S *  
lastlog  
chage -l <user>
```

Analyse à faire :

- Politique expiration mot de passe ?
- Comptes jamais connectés ?
- Comptes actifs sans justification ?

PARTIE C — Analyse des services

Services actifs avec démarrage automatique

```
systemctl list-unit-files --state=enabled  
systemctl list-units --type=service --state=running
```

Croiser :

- Services activés au boot
- Services réellement nécessaires

Analyse des dépendances

```
systemctl list-dependencies
```

Objectif : Comprendre la chaîne de dépendance critique.

Services exposés réseau

```
ss -tulnp  
lsof -i -P -n
```

Puis croiser avec :

```
ps aux
```

Ils doivent produire un tableau :

| Port | Processus | Utilité | Nécessaire ? | Risque potentiel |

PARTIE D — Analyse des permissions critiques

Fichiers SUID / SGID

```
find / -perm -4000 -type f 2>/dev/null  
find / -perm -2000 -type f 2>/dev/null
```

Identifier :

- Binaries sensibles

- Risques d'escalade

Fichiers world-writable

```
find / -perm -002 -type f 2>/dev/null
```

Analyse :

- Risque injection
- Risque modification binaire

PARTIE E — Configuration SSH approfondie

```
cat /etc/ssh/sshd_config
```

Vérifier :

- PermitRootLogin
- PasswordAuthentication
- X11Forwarding
- AllowUsers
- Port modifié ?
- Protocol version ?

Ensuite :

```
ss -tulnp | grep ssh
```

PARTIE F — Analyse réseau

Interfaces et routage

```
ip a
```

```
ip route
```

Vérifier :

- Interfaces inutiles
- ip_forward activé ?

Paramètres réseau sensibles

```
sysctl -a | grep net
```

Analyser :

- SYN cookies
- ICMP redirect

- Source routing

PARTIE G — Analyse des tâches planifiées

crontab -l

ls -la /etc/cron*

Objectif :

- Détecter tâches suspectes
- Vérifier permissions

PARTIE H — Vérification des logs et rotation

cat /etc/rsyslog.conf

cat /etc/logrotate.conf

Analyser :

- Rotation activée ?
- Logs trop permissifs ?
- Logs world-readable ?

Livrables à la fin de cette phase

1. Tableau synthèse des vulnérabilités détectées
2. Analyse argumentée (pas juste du copier-coller)

Etape 2 : Installation des outils de sécurité et d'audit

Lynis – Audit et hardening du système

Lynis est un outil d'audit de sécurité permettant d'analyser la configuration d'un serveur linux et de proposer des recommandations d'amélioration.

Principales fonctionnalités :

- Vérification des mises à jour et correctifs de sécurité
- Analyse des permissions et des configurations critiques
- Détection des services et processus non sécurisés
- Recommandations pour renforcer la sécurité

Installation :

`sudo apt install lynis`

Lancement d'un audit (une première exécution pour valider la bonne installation):

`sudo lynis audit system`

Le travail à réaliser est d'analyser le rapport lynis et relever : failles, mauvaises configurations, recommandations.

But : lire un rapport d'audit technique.

Exemple de résultat :

```
=====
-[ Lynis 3.0.9 Results ]-

Warnings (3):
-----
! Can't find any security repository in /etc/apt/sources.list or sources.list.d directory [PKGS-7388]
  https://cisofy.com/lynis/controls/PKGS-7388/

! Found one or more vulnerable packages. [PKGS-7392]
  https://cisofy.com/lynis/controls/PKGS-7392/

! Found some information disclosure in SMTP banner (OS or software name) [MAIL-8818]
  https://cisofy.com/lynis/controls/MAIL-8818/

Suggestions (48):
-----
* This release is more than 4 months old. Check the website or GitHub to see if there is an update available. [LYNIS]
  https://cisofy.com/lynis/controls/LYNIS/

* Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions [DEB-0280]
  https://cisofy.com/lynis/controls/DEB-0280/

* Install apt-listbugs to display a list of critical bugs prior to each APT installation. [DEB-0810]
  https://cisofy.com/lynis/controls/DEB-0810/

=====

Lynis security scan details:

Hardening index : 61 [#####          ]
Tests performed : 261
Plugins enabled  : 1

Components:
- Firewall           [V]
- Malware scanner    [V]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status  [?]
- Security audit      [V]
- Vulnerability scan  [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat

=====

Lynis 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021, CISOfy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)

=====

[TIP]: Enhance Lynis audits by adding your settings to custom.prf (see /etc/lynis/default.prf for all settings)
```

Nikto – Scanner de sécurité web

Nikto analyse les failles des serveurs web (Apache, Nginx, etc.).

Nécessite l'installation et la configuration d'un serveur, Apache par exemple.

Principales fonctionnalités :

- Détection de fichiers et répertoires sensibles accessibles
- Vérification des vulnérabilités liées aux versions des serveurs web
- Scan des en-têtes HTTP pour repérer les mauvaises configurations

Installation :

```
sudo apt install nikto
```

Commande :

```
sudo nikto -h http://<IP_du_serveur>
```

But : apprendre à analyser un serveur web.

Chkrootkit – Détection de Rootkits

Chkrootkit est un outil permettant de détecter la présence de **rootkits** (programmes malveillants qui permettent un accès furtif au système).

Principales fonctionnalités :

- Vérification des binaires systèmes modifiés
- Détection des processus cachés malveillants
- Scan des fichiers système pour repérer des comportements suspects

Installation :

```
sudo apt install chkrootkit
```

Commande :

```
sudo chkrootkit
```

But : détection des rootkits, backdoors et les exploits locaux.

Rkhunter – Analyse de Rootkits et Backdoors

Rootkit Hunter (Rkhunter) est un autre outil de détection de rootkits, backdoors et exploits.

Principales fonctionnalités :

- Vérification de l'intégrité des fichiers système
- Détection de permissions suspectes
- Analyse des ports ouverts et processus cachés

Installation:

```
sudo apt install rkhunter
```

Commande :

```
sudo rkhunter --check --skip-keypress
```

But : détection des rootkits, backdoors et les exploits locaux.

Auditd – Surveillance et journalisation des événements sécuritaires

Utilité : Auditd (Audit Daemon) permet de surveiller les actions critiques sur le serveur et de générer des logs détaillés.

Principales fonctionnalités :

- Enregistrement des commandes exécutées par les utilisateurs
- Détection des tentatives d'accès non autorisées
- Analyse des modifications des fichiers sensibles

Installation :

```
sudo apt install auditd
```

Commande pour activer Auditd :

```
sudo systemctl enable auditd
```

```
sudo systemctl start auditd
```

Vérifier les logs :

```
sudo ausearch -m avc
```

But : identification des actions critiques sur les serveurs.

Fail2Ban

Utilité : Fail2Ban bloque automatiquement les adresses IP effectuant trop de tentatives de connexion échouées.

Principales fonctionnalités :

- Détection des tentatives de connexion SSH répétées
- Blocage des attaques brute force
- Ajout automatique des IP malveillantes au pare-feu

Installation :

```
sudo apt install fail2ban
```

Commande pour activer Fail2Ban :

```
sudo systemctl enable fail2ban
```

```
sudo systemctl start fail2ban
```

Vérifier les adresses IP bannies :

Réaliser plusieurs tentatives de connexion au serveur en ssh et ensuite vérifier si l'adresse IP source a été rajoutée à la liste.

```
sudo fail2ban-client status sshd
```

UFW

Utilité : UFW est une interface simplifiée pour gérer les règles iptables et protéger un serveur des connexions non autorisées.

Principales fonctionnalités :

- Blocage ou autorisation des ports
- Restriction des accès SSH et HTTP(S)
- Suivi des tentatives de connexion suspectes

Installation :

```
sudo apt install ufw
```

Commande pour activer UFW :

```
sudo ufw enable
```

Autoriser les SSH et HTTP(S) :

```
sudo ufw allow 22/tcp
```

```
sudo ufw allow 80/tcp
```

```
sudo ufw allow 443/tcp
```

```
sudo ufw status verbose
```

AppArmor – Sécurisation des applications

AppArmor applique des profils de confinement aux applications pour limiter les actions qu'elles peuvent effectuer sur le système.

Principales fonctionnalités :

- Protection contre l'exploitation des services exposés
- Restriction des accès aux fichiers et ressources système
- Détection des tentatives d'exécution non autorisées

Installation :

```
sudo apt install apparmor
```

Commande pour vérifier le statut d'AppArmor :

```
sudo aa-status
```

Activer AppArmor :

```
sudo systemctl enable apparmor
```

```
sudo systemctl start apparmor
```

ClamAV – Antivirus pour Linux

ClamAV permet de scanner un serveur pour détecter les malwares et les virus.

Principales fonctionnalités :

- Analyse des fichiers et courriels
- Détection des logiciels malveillants
- Mises à jour régulières des bases de signatures

Installation :

```
sudo apt install clamav -y
```

Mettre à jour la base de signatures :

```
sudo freshclam
```

Scanner le serveur :

```
sudo clamscan -r /
```

YARA – Détection Avancée de Malware

YARA est un outil avancé de détection de malwares basé sur des règles de signature.

Principales fonctionnalités :

- Analyse de fichiers suspects
- Détection des comportements malveillants
- Création de règles personnalisées pour détecter des menaces spécifiques

Installation :

```
sudo apt install yara -y
```

Scanner un répertoire avec YARA :

```
sudo yara -r /usr /var /etc
```

Tableau de synthèse des outils

Outil	Utilité principale
Lynis	Audit de sécurité et recommandations
OpenVAS	Scanner de vulnérabilités réseau
Nikto	Analyse de sécurité web
Chkrootkit / Rkhunter	Détection de rootkits et backdoors
Auditd	Journalisation des événements de sécurité
Fail2Ban	Protection contre les attaques brute force
ufw	Gestion du pare-feu (iptables)
AppArmor	Confinement des applications
ClamAV	Détection de malwares et virus
YARA	Détection avancée de menaces

Etape 3 : Vérifications de l'état du serveur (post installation outils)

Vérification des services actifs

Objectif : Identifier les services en cours d'exécution et détecter ceux qui ne sont pas nécessaires ou mal configurés.

Lister tous les services actifs

```
sudo systemctl list-units --type=service --state=running
```

Identifier les ports ouverts et les services associés

```
sudo ss -tulnp
```

Vérifier les connexions réseau établies

```
sudo netstat -anp | grep ESTABLISHED
```

Action : Désactiver les services inutiles pour réduire la surface d'attaque.

```
sudo systemctl disable <nom_du_service>
```

```
sudo systemctl stop <nom_du_service>
```

Identification des processus et des utilisateurs actifs

Objectif : Repérer les processus anormaux ou suspects ainsi que les comptes utilisateurs actifs. N'hésitez pas de créer des process ou des users pour le montrer.

Lister les processus actifs

```
ps aux --sort=-%mem | head -20
```

Vérifier les utilisateurs connectés

```
who -a
```

Lister les utilisateurs disposant d'un shell interactif

```
cat /etc/passwd | grep "/bin/bash"
```

Action :

- **Désactiver les comptes inutilisés**

```
sudo usermod -L <nom_utilisateur>
```

- **Supprimer les utilisateurs non reconnus**

```
sudo deluser <nom_utilisateur>
```

Cartographie du Réseau et Identification des Menaces

Objectif : Obtenir une vue complète du réseau, des équipements connectés, des flux de communication et des menaces potentielles.

Scan des ports et des services exposés avec nmap

Même si l'infrastructure est limitée il est possible de scanner le serveur avec nmap.

```
sudo apt install nmap
```

```
sudo nmap -sV localhost
```

Objectif :

- découvrir les services actifs
- comprendre la surface d'exposition

Très sécurisé : scan sur soi-même uniquement.

Vérifier les connexions actives, identifier les flux légitimes et détecter les anomalies

Lister les Connexions Actives

- Afficher les connexions TCP/UDP : `sudo ss -tulnp`
- Surveiller les connexions établies : `sudo netstat -antp`

Suivi des Requêtes DNS et des Communications Externes

- Voir les requêtes DNS en temps réel :
`sudo tcpdump -i eth0 port 53`
- Lister les connexions externes suspectes :
`sudo lsof -i -P -n | grep ESTABLISHED`

Visualisation en Temps Réel des Connexions Suspectes

1. Analyse des trafic réseau avec Tshark
 - Capturer les paquets en temps réel sur une interface : `sudo tshark -i eth0`
 - Capturer uniquement les connexions SSH : `sudo tshark -i eth0 port 22`
2. Détection d'anomalies avec suricata

Installer un IDS (Intrusion Detection System) pour repérer les attaques réseau.

```
sudo apt install suricata -y
```

```
sudo suricata -c /etc/suricata/suricata.yaml -i eth0
```

Analyser les alertes générées :

```
sudo tail -f /var/log/suricata/fast.log
```

Détection des appareils et des adresses MAC sur le réseau avec arp-scan

Installation :

```
sudo apt install arp-scan
```

1. Liste des hôtes connectés au réseau
`sudo arp-scan --localnet`
2. Détection des adresses MAC suspectes

Repérer des appareils inconnus.

`sudo arp -a`

Comparer avec une liste d'adresses MAC autorisées.

Vérification des Flux de Données et des Pare-feu

1. Vérification des règles de Pare-feu

`sudo iptables -L -v -n`

2. Analyse des logs du Firewall

`sudo ufw logging on`

`sudo tail -f /var/log/ufw.log`

Recherche des services non sécurisés

But : Détecter des services qui pourraient être exploités.

1. Identifier les Services en Écoute

`sudo systemctl list-units --type=service --state=running`

2. Désactiver un service inutile

`sudo systemctl disable <service>`

`sudo systemctl stop <service>`

Détection d'activités suspectes avec Fail2Ban

But : Repérer et bloquer les tentatives d'intrusion.

1. Afficher les Adresses IP Bannies

`sudo fail2ban-client status sshd`

2. Examiner les Tentatives de Connexion Suspectes

`sudo cat /var/log/auth.log | grep "Failed password"`

Questions à traiter à la fin de la Phase 1

En réponse à chaque question une fiche de compréhension et à réaliser.

Question 1

Pourquoi la version du noyau Linux est-elle un élément critique en audit ?
Expliquez le lien entre version kernel, CVE et surface d'attaque.

Question 2

Quelle est la différence entre un compte système et un compte humain ?
Pourquoi un UID 0 multiple est-il critique ?

Question 3

Expliquez pourquoi un service activé au démarrage mais non utilisé représente un risque.
Illustrer avec un exemple concret.

Question 4

Pourquoi les fichiers SUID peuvent-ils permettre une escalade de privilèges ?
Donnez un scénario simple.

Question 5

Expliquez la relation entre configuration SSH, authentification et attaque brute force.
Quels paramètres sont critiques et pourquoi ?

Question 6

Expliquez pourquoi Lynis, Chkrootkit, Rkhunter et ClamAV ne remplissent pas le même rôle, même s'ils semblent tous scanner le système.

Question 7

Un système obtient un score Lynis élevé et aucun rootkit détecté. Peut-on conclure qu'il est sécurisé ?
Justifiez techniquement.

Question 8

En vous appuyant sur UFW, Fail2Ban, AppArmor et Auditd, expliquez comment ces outils participent à une stratégie de défense en profondeur.

Question 9

Classez les outils utilisés selon qu'ils relèvent principalement de la prévention, de la détection ou de la réponse à incident. Justifiez.

Question 10

Proposez un scénario d'attaque simple (par exemple brute force SSH) et expliquez comment au moins 4 outils différents permettraient de détecter ou bloquer cette attaque.

Phase 2 : Audit de sécurité et détection des menaces

Méthode structurée pour analyser le rapport Lynis

Décomposition de l'analyse en 8 étapes.

Etape A — Identifier les sections clés

Lancement d'un audit (une deuxième exécution aussi pour comparer avec la première):

```
sudo lynis audit system
```

Dans sa sortie, Lynis affiche des blocs tels que :

- **Boot & Services**
- **Kernel Hardening**
- **File Permissions**
- **Authentication**
- **Networking**
- **Firewall**
- **Malware Scanners**
- **Logging & Auditing**

Exercice : Repérer 5 sections dans le rapport et noter leur rôle dans la sécurité du système.

Exemple : “*Kernel Hardening*” indique si le noyau Linux utilise des mécanismes de protection comme ASLR, kernel lockdown, protections mémoire...”

Etape B — Identifier tous les Warnings (WGN)

Les warnings sont les éléments les plus importants.

Ils sont notés comme ceci :

```
[WARNING] Default umask value is too weak (022)
```

Exercice : Relever au moins 3 Warnings .Pour chacun expliquer ce que cela signifie.

Exemple d'interprétation :

Warning :

```
Default umask value is too weak (022)
```

Signification pédagogique :

“022 signifie que les nouveaux fichiers créés sont trop permissifs. Les utilisateurs peuvent lire les fichiers d'autres utilisateurs.”

Risque : fuite de données ou accès non autorisé.

Etape C — Identifier les Suggestions (SGN)

Les suggestions sont notées :

[Suggestion] Enable password aging to enforce regular password updates

Exercice : Relever au moins 5 suggestions et les classer par thème : comptes, réseau, permissions, services.

Etape D — Lire le score de sécurité

En fin de rapport :

Hardening index: 61 [INCREASE]

Objectif : apprendre que le score Lynis :

- est relatif (pas une norme)
- compare le système à des benchmarks CIS / standards généraux
- permet de mesurer l'amélioration avant/après durcissement

Exercice : Noter votre score actuel. Le comparer à l'objectif ≥ 90 après corrections.

Etape E — Trouver les éléments non configurés / non détectés

Lynis signale souvent :

[Missing] No anti-malware tool installed

[Missing] Firewall not active

[Missing] No audit rules found

Exercice : Identifier 3 Missing et expliquer pourquoi cela pose un problème de sécurité ?

Etape F — Vérifier la partie Logging et Auditing

Lynis analyse souvent : rsyslog, auditd, rotation des logs, permissions des logs.

Exercice : Identifier 2 problèmes dans la section logging. Expliquer leur impact (ex : impossibilité d'enquêter après incident, perte de traces).

Etape G — Compiler les 5 failles les plus importantes

Créer un tableau comme celui-ci :

ID	Vulnérabilité Lynis	Signification	Risque	Priorité	Correctif recommandé
LYN-01	Firewall inactive	Aucun filtrage réseau	Intrusions	Haute	Activer UFW
LYN-02	Root login permitted	SSH trop permissif	Compromission totale	Critique	Désactiver root login

Objectif : apprendre à contextualiser un résultat technique et à proposer un correctif réaliste.

Exécution du scan d'audit et sauvegarder le résultat dans un fichier d'audit.

```
sudo lynis audit system
```

Étape H — Détection des Rootkits et Malwares

1. Scan du système avec Chkrootkit et Rkhunter

```
sudo chkrootkit
```

```
sudo rkhunter --check
```

2. Scan des fichiers avec ClamAV et Yara (détection avancée de malwares et ransomwares)

```
sudo freshclam # Mise à jour de la base de données des signatures
```

```
sudo clamscan -r / --bell --exclude-dir=/sys
```

```
sudo yara /var/lib/yara-rules / -r
```

Questions à traiter à la fin de la Phase 2

En réponse à chaque question une fiche de compréhension et à réaliser.

Question 1

Vous avez exécuté Lynis deux fois. Expliquez pourquoi les résultats peuvent différer entre deux scans successifs sur le même système.

Question 2

Parmi les warnings identifiés tous les warnings ont-ils le même niveau de criticité réelle ? Justifiez en distinguant : vulnérabilité exploitable immédiatement, faiblesse de configuration et recommandation de bonnes pratiques.

Question 3

Le score Lynis passe de 61 à 88 (à titre d'exemple).

Peut-on conclure que le système est sécurisé ? Expliquez les limites du Hardening Index.

Question 4

Choisissez un élément **Missing** identifié.

Expliquez : pourquoi il est signalé, ce qu'il implique techniquement, ce que cela permettrait à un attaquant, la correction minimale nécessaire.

Question 5

Si Lynis signale une faiblesse dans la journalisation, expliquez comment cela pourrait empêcher la reconstruction d'un incident réel.

Question 6

Chkrootkit et Rkhunter ne détectent rien. Peut-on conclure qu'aucune compromission n'existe ? Expliquez les limites des outils à base de signatures.

Question 7

Imaginez une attaque brute force SSH suivie d'une escalade de privilèges.

Décrivez comment au moins 5 outils de la phase 2 pourraient intervenir (détection ou prévention).

Question 8

Expliquez la différence entre faux positif et faux négatif dans le contexte de Lynis, ClamAV et Rkhunter puis précisez lequel est le plus dangereux en environnement critique ? Pourquoi ?

Question 9

Dans votre tableau des 5 failles principales, sur quels critères avez-vous classé les priorités ? Justifiez en utilisant : impact, probabilité, exploitabilité, exposition, effort de correction.

Phase 3 : Sécurisation et mise en conformité

Etape 1 : Hardening Système

Mise à jour maîtrisée

Au lieu de simplement appliquer

```
sudo apt upgrade -y
```

Passez par :

```
sudo apt update
```

```
sudo apt list --upgradable
```

```
sudo apt upgrade
```

Et ensuite analyser : les paquets critiques (openssl, openssh, kernel), les CVE associées, les impacts possibles.

Durcissement SSH complet

Modifier :

```
sudo nano /etc/ssh/sshd_config
```

Implémenter :

- PermitRootLogin no
- PasswordAuthentication no (si clé configurée)
- MaxAuthTries 3
- LoginGraceTime 30
- AllowUsers <user>
- Port personnalisé
- X11Forwarding no

Puis relancer le service :

```
sudo systemctl restart ssh
```

Mesurer : test de connexion et vérification des logs

Pare-feu avancé (micro-segmentation locale)

Au lieu de seulement ouvrir 22 et 80 :

```
sudo ufw default deny incoming
```

```
sudo ufw default allow outgoing
```

```
sudo ufw allow from <IP_DE_CONFIANCE> to any port 22
```

```
sudo ufw limit 22/tcp
sudo ufw logging on
```

Objectif : restreindre IP SSH, activer rate limiting, activer la journalisation

Durcissement sysctl (Kernel Hardening)

Créer fichier :

```
sudo nano /etc/sysctl.d/99-hardening.conf
```

Ajouter :

```
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.all.send_redirects = 0
net.ipv4.tcp_syncookies = 1
net.ipv4.ip_forward = 0
kernel.randomize_va_space = 2
```

Appliquer :

```
sudo sysctl -p /etc/sysctl.d/99-hardening.conf
```

Objectif : réduire surface réseau et attaques MITM.

Politique de mots de passe renforcée

Configurer :

```
sudo nano /etc/login.defs
```

Puis PAM :

```
sudo nano /etc/pam.d/common-password
```

Pour ajouter les règles : longueur minimale, complexité, expiration, historique.

Suppression des fichiers SUID inutiles

Identifier les fichiers :

```
find / -perm -4000 -type f 2>/dev/null
```

Analyser chaque binaire et supprimer si inutile :

```
sudo chmod u-s <file>
```

Etape 2 : Conformité

AppArmor – Profil personnalisé

Pas seulement :

```
sudo aa-enforce /etc/apparmor.d/*
```

Mais :

- Vérifier profils actifs
- Passer en complain
- Observer logs
- Ajuster profil pour Apache

sudo aa-status

Protection des logs

- `chmod 640 /var/log/*`
- `config logrotate`
- `auditctl` pour fichiers sensibles

Mise en place Fail2Ban avancé

Créer configuration custom :

`sudo nano /etc/fail2ban/jail.local`

Modifier : bantime, findtime, maxretry, email notification.

Etape 3 – Validation et Mesure

Repasser Lynis

Comparer :

- Score avant
- Score après
- Warnings restants

Objectif ≥ 90

Repasser Chkrootkit / Rkhunter

Comparer l'état.

Vérifier la réduction surface réseau

Comparer `ss -tulnp` avant et après.

Questions à traiter à la fin de la Phase 3

En réponse à chaque question une fiche de compréhension et à réaliser.

Question 1

Pourquoi un durcissement excessif peut-il devenir contre-productif en environnement réel ?

Question 2

Expliquez la différence entre conformité (CIS) et sécurité réelle.

Question 3

Quelle est la logique de défense en profondeur appliquée dans cette phase 3 ?

Question 4

Pourquoi certaines recommandations CIS ne sont-elles pas toujours applicables ?

Question 5

Après avoir renforcé SSH, le pare-feu et les politiques PAM :

- Quels risques opérationnels avez-vous potentiellement introduits ?
- Donnez au moins 3 exemples concrets.

Phase 4 : Surveillance continue

Mise en place de la surveillance active

1. Activation et configuration d'auditd pour surveiller les accès aux fichiers critiques

```
sudo auditctl -w /etc/passwd -p wa -k passwd_changes
```

```
sudo auditctl -w /etc/shadow -p wa -k shadow_changes
```

2. Déploiement de wazuh comme SIEM pour surveiller les logs et alertes

```
sudo systemctl start wazuh-agent
```

Etape 1 : Auditd

Configuration des règles auditd

Construire un fichier de règles persistant :

```
sudo nano /etc/audit/rules.d/hardening.rules
```

Exemples à ajouter :

```
-w /etc/passwd -p wa -k identity_modification  
-w /etc/shadow -p wa -k credential_modification  
-w /etc/sudoers -p wa -k privilege_escalation  
-w /var/log/auth.log -p wa -k log_tampering  
-a always,exit -F arch=b64 -S execve -k command_execution  
-a always,exit -F arch=b64 -S setuid -k privilege_change
```

Ensuite : `sudo augenrules --load`

Objectif : surveiller les actions critiques et non juste les fichiers.

Analyse des événements

Utiliser :

```
sudo ausearch -k identity_modification  
sudo ausearch -k privilege_change  
sudo aureport -au  
sudo aureport -x
```

Ensuite : interpréter les événements, identifier UID, PID, commande exécutée et déterminer si légitime ou suspect.

Etape 2 : Détection comportementale simple

A simuler :

- Création d'un nouvel utilisateur
- Modification sudoers

- Tentative brute force
- Suppression log

Puis observer :

- Déclenchement auditd
- Traces dans auth.log
- Corrélation événements

Etape 3 : Wazuh comme SIEM simplifié

Comprendre l'architecture

Expliquer :

- Agent vs manager
- Collecte de logs
- Décodage
- Règles
- Alertes

Vérification du fonctionnement

```
sudo systemctl status wazuh-agent
```

Puis vérifier :

- Alertes générées
- Niveau de sévérité
- Type d'événement

Création d'une règle personnalisée

Exemple :

Détecter plus de 3 modifications de passwd en 5 minutes.

Objectif : comprendre la logique :

- Log source
- Pattern
- Condition
- Seuil
- Action

Etape 4 : Corrélation multi-sources

Produire un mini scénario, à titre d'exemple :

Brute force SSH, connexion réussie, ajout utilisateur, modification sudoers

A démontrer :

- Où apparaît chaque événement
- Dans quel outil
- Dans quel ordre
- Quel délai de détection

Questions à traiter à la fin de la Phase 4

En réponse à chaque question une fiche de compréhension et à réaliser.

Question 1

Quelle est la différence entre journalisation (logging) et surveillance active (monitoring) ?

Question 2

Pourquoi la corrélation d'événements est-elle essentielle en détection d'intrusion ?

Question 3

Quelles limites présente un SIEM sur une seule machine ?

Question 4

Comment réduire les faux positifs sans diminuer la sécurité ?

Question 5

Quels événements critiques doivent absolument être surveillés sur un serveur exposé ?

Phase 5: Rapport final

Rédaction du rapport dans lequel il faut faire apparaître a minima les sections suivantes.

Section 1 : Synthèse des vulnérabilités identifiées et des correctifs appliqués

Cette section est une vue d'ensemble claire et lisible des failles trouvées et des actions menées.

Section 2 : Comparaison des scores de sécurité avant / après

Section 3 : Recommandations pour une amélioration continue et une surveillance proactive

Section 4 : Proposition d'un plan d'action final

Livrables attendus

- Rapport détaillé avec captures d'écran des audits et corrections appliquées
- Logs des outils d'analyse et de détection

ANNEXE

Exemple de plan de rapport

1. Introduction

1.1 Contexte de l'audit

- Objectifs et périmètre de l'audit
- Conformité aux réglementations et normes (ISO 27001, SOC 2, NIS 2, DORA, RGPD, ...)
- Type d'environnement audité (serveurs, réseau, applications, cloud)

1.2 Méthodologie de l'audit

- Approche adoptée (analyse manuelle, outils de scanning, tests d'intrusion)
- Outils utilisés (Lynis, Nmap, OpenVAS, Nessus, ...)
- Référentiels de bonnes pratiques (CIS Benchmarks, OWASP, NIST, ANSSI)

2. Résumé exécutif

2.1 Synthèse des résultats

- État général de la sécurité du système
- Principaux risques identifiés
- Score de sécurité (si applicable)

2.2 Principales vulnérabilités détectées

- Vulnérabilités critiques (exploitation immédiate possible)
- Vulnérabilités modérées (risques)
- Mesures de remédiation prioritaires

2.3 Recommandations stratégiques

- Actions urgentes à mettre en place
- Améliorations à prévoir à moyen et long terme

3. Détails Techniques de l'Audit

3.1 Analyse de la Sécurité Système

- Système d'exploitation
- Etat des mises à jour et correctifs de sécurité
- Analyse des configurations critiques (kernel, logs, permissions)
- Éléments détectés avec les outils de scanning

3.2 Sécurité Réseau et Services Exposés

- Liste des ports ouverts et services actifs
- Configuration du pare-feu (ufw, iptables, etc.)
- Détection des connexions suspectes ou non sécurisées

3.3 Gestion des Accès et Authentification

- Gestion des comptes et privilèges (utilisateurs sudoers, comptes dormants)
- Analyse des logs de connexion SSH et tentatives d'intrusion
- Politique de mots de passe

3.4 Sécurité Applicative et Web

- Tests d'injections
- Utilisation de composants tiers vulnérables
- Configuration des certificats SSL/TLS et sécurisation des API

3.5 Sécurité des Données et Cryptographie

- Chiffrement des données sensibles (disques, bases de données, fichiers)
- Gestion des sauvegardes et restauration
- Journalisation et surveillance des événements de sécurité

4. Classement et évaluation des vulnérabilités

ID	Type de Vulnérabilité	Impact	Niveau de Sévérité ● Critique ● Modéré ● Faible	Priorité de Correction
VULN-01	SSH root login activé	Risque d'intrusion	● Critique	Haute
VULN-02	Ports ouverts inutilisés	Risque d'exploitation	● Modéré	Moyenne
VULN-03	Mises à jour système manquantes	Exploitation de CVE	● Critique	Haute
VULN-04	Absence de journalisation centralisée	Manque de traçabilité	● Faible	Basse

5. Recommandations et Plan d'Action

5.1 Corrections immédiates

- Désactiver les accès critiques
- Appliquer les mises à jour de sécurité et corriger les CVE
- Restreindre les ports ouverts et durcir la configuration réseau

5.2 Corrections à moyen terme

- Mettre en place un monitoring centralisé
- Durcir la politique de mots de passe et activer MFA
- Renforcer la protection des données avec du chiffrement avancé

5.3 Corrections à long terme

- Formation des utilisateurs et sensibilisation aux cybermenaces
- Automatisation des tests de sécurité et audits réguliers
- Mise en place d'un plan de reprise d'activité

6. Conclusion et Perspectives

- Résumé des actions prioritaires

- Stratégie d'amélioration continue
- Proposition d'un suivi régulier des mesures de sécurité

Annexes :

- Captures d'écran des résultats de scan
- Logs et fichiers de configuration analysés
- Liens vers les CVE détectées